

Assignment 1 – Simulating a Security Audit based on ISO27001:2022

As part of Assignment 1, here is a list of all ISO 27001:2022 controls, along with example questions to guide the Audit execution.

Organizational Controls (37 controls)

A.5.1 Policies for Information Security

- **Question:**
 - We can find an information security policy that identifies the main security challenges and strategies.
 - Are information security policies established, approved by management, communicated to relevant parties, and regularly reviewed?

A.5.2 Information Security Roles and Responsibilities

- **Question:** Are the organization's information security roles and responsibilities clearly defined, assigned, and communicated?

A.5.3 Segregation of Duties

- **Question:** Is there an adequate segregation of duties to reduce the risk of fraud or error?

A.5.4 Management Responsibilities

- **Question:** Does management actively support information security initiatives and ensure their integration into organizational processes?

A.5.5 Contact with Authorities

- **Question:** Are there procedures to establish and maintain contact with relevant authorities on information security matters?

A.5.6 Contact with Special Interest Groups

- **Question:** Does the organization participate in special interest groups or forums related to information security to stay informed about threats and best practices?

A.5.7 Threat Intelligence

- **Question:** Is there a process to gather, analyze, and respond to information about emerging security threats?

A.5.8 Information Security in Project Management

- **Question:** Are information security requirements identified and addressed in project management activities?

A.5.9 Inventory of Information and Other Associated Assets

- **Question:** Is there an up-to-date inventory of information assets, including ownership and classification?

A.5.10 Acceptable Use of Information and Other Associated Assets

- **Question:** Are rules for the acceptable use of information and assets documented and communicated to all users?

A.5.11 Return of Assets

- **Question:** Is there a process to ensure that employees and external parties return all organizational assets upon termination of their employment or contract?

A.5.12 Classification of Information

- **Question:** Is information classified based on its value, sensitivity, and criticality to the organization?

A.5.13 Labeling of Information

- **Question:** Are appropriate labels applied to information based on its classification?

A.5.14 Information Transfer

- **Question:** Are there policies and procedures to protect information during transfer, both within and outside the organization?

A.5.15 Access Control

- **Question:** Are access control policies established, documented, and reviewed based on business and information security requirements?

A.5.16 Identity Management

- **Question:** Is there a process for managing the lifecycle of user identities, including provisioning and de-provisioning?

A.5.17 Authentication Information

- **Question:** Are allocation and management of authentication information (e.g., passwords, tokens) securely managed?

A.5.18 Access Rights

- **Question:** Are user access rights reviewed regularly, and are unnecessary access rights removed promptly?

A.5.19 Information Security in Supplier Relationships

- **Question:** Have information security requirements for supplier relationships been identified and managed?

A.5.20 Addressing Information Security Within Supplier Agreements

- **Question:** Do supplier agreements include appropriate information security requirements?

A.5.21 Managing Information Security in the ICT Supply Chain

- **Question:** Is there a process to manage information security risks associated with the ICT supply chain?

A.5.22 Monitoring, Review, and Change Management of Supplier Services

- **Question:** Are supplier services regularly monitored, reviewed, and managed for changes affecting information security?

A.5.23 Information Security for Use of Cloud Services

- **Question:**
 - Are risks associated with using cloud services identified and managed?
 - Have the shared responsibilities been clarified with the Cloud Provider?

A.5.24 Information Security Incident Management Planning and Preparation

- **Question:**
 - Have procedures for managing information security incidents been established and tested?
 - Are the procedures for incident management communicated to the organization?

A.5.25 Assessment and Decision on Information Security Events

- **Question:** Is there a process to assess and decide on information security events?

A.5.26 Response to Information Security Incidents

- **Question:** Are information security incidents responded to following documented procedures?

A.5.27 Learning from Information Security Incidents

- **Question:** Are lessons learned from information security incidents used to improve the incident management process?

A.5.28 Collection of Evidence

- **Question:** Is there a procedure for collecting, retaining, and presenting evidence related to information security incidents?

A.5.29 Information Security During Disruption

- **Question:** Are information security details integrated into the organization's business continuity management processes?

A.5.30 ICT Readiness for Business Continuity

- **Question:** Are ICT services prepared to support business continuity objectives during disruptions?

A.5.31 Legal, Statutory, Regulatory, and Contractual Requirements

- **Question:** Are all relevant legal, statutory, regulatory, and contractual requirements concerning information security identified and documented?

A.5.32 Intellectual Property Rights

- **Question:** Are policies and procedures in place to protect intellectual property rights?

A.5.33 Protection of Records

- **Question:** Are records protected from loss, destruction, falsification, and unauthorized access?

A.5.34 Privacy and Protection of Personally Identifiable Information (PII)

- **Question:** Are privacy and protection of PII ensured in accordance with relevant legislation and regulations?

A.5.35 Independent Review of Information Security

- **Question:**
 - Are independent reviews or audits of information security regularly scheduled and conducted?
 - Is the scope of independent reviews clearly defined, and does it cover key security processes, systems, and controls?

People Controls (8 controls)

A.6.1 Screening

- **Question:** Are background verification checks conducted on all candidates for employment, including contractors, under relevant laws, regulations, and ethics, and proportional to the business requirements, the classification of the information to be accessed, and the perceived risks?

A.6.2 Terms and Conditions of Employment

- **Question:** Do employment agreements contain clauses requiring employees and contractors to comply with the organization's information security policies and procedures?

A.6.3 Information Security Awareness, Education, and Training

- **Question:** Is there an ongoing information security awareness program educating employees and contractors on their responsibilities?

A.6.4 Disciplinary Process

- **Question:** Is there a formal disciplinary process for employees and contractors who have committed information security breaches?

A.6.5 Responsibilities After Termination or Change of Employment

- **Question:** Are there policies and procedures to ensure that information security responsibilities and duties remain valid after termination or change of employment are communicated to the departing employee or contractor?

A.6.6 Confidentiality or Non-Disclosure Agreements

- **Question:** Are employees and contractors required to sign confidentiality or non-disclosure agreements before being granted access to sensitive information?

A.6.7 Remote Working

- **Question:** Are security measures implemented to protect information accessed, processed, or stored outside the organization's premises, such as in remote working scenarios?

A.6.8 Return of Assets

- **Question:** Is there a process to ensure that all organizational assets issued to employees and contractors are returned upon termination or change of employment?

Physical Controls (14 controls)

A.7.1 Physical Security Perimeter

- **Question:** Are physical security perimeters defined and implemented to protect areas that contain sensitive or critical information and information processing facilities?

A.7.2 Physical Entry Controls

- **Question:** Do appropriate entry controls protect secure areas to ensure that only authorized personnel are allowed access?

A.7.3 Securing Offices, Rooms, and Facilities

- **Question:** Are offices, rooms, and facilities designed and configured to protect sensitive information from unauthorized access and environmental threats?

A.7.4 Protecting Against External and Environmental Threats

- **Question:** Are physical protection measures implemented against natural disasters, malicious attacks, or accidents?

A.7.5 Working in Secure Areas

- **Question:** Are procedures established for working in secure areas, including controls for access, supervision, and monitoring?

A.7.6 Delivery and Loading Areas

- **Question:** Are access points such as delivery and loading areas controlled and, if possible, isolated from information processing facilities to avoid unauthorized access?

A.7.7 Equipment Siting and Protection

- **Question:** Is equipment sited or protected to reduce risks from environmental threats, hazards, and opportunities for unauthorized access?

A.7.8 Supporting Utilities

- **Question:** Are equipment and information processing facilities protected from power failures and other disruptions caused by failures in supporting utilities?

A.7.9 Cabling Security

- **Question:** Are power and telecommunications cables carrying data or supporting information services protected from interception, interference, or damage?

A.7.10 Equipment Maintenance

- **Question:** Is equipment maintained correctly to ensure its continued availability and integrity?

A.7.11 Removal of Assets

- **Question:** Is equipment, information, or software removed from the organization's premises subject to prior authorization and logged?

A.7.12 Security of Equipment and Assets Off-Premises

- **Question:** Are security measures implemented to protect off-site assets, considering the different risks of working outside the organization's premises?

A.7.13 Secure Disposal or Reuse of Equipment

- **Question:** Are media containing sensitive information securely erased or destroyed before disposal or reuse?

A.7.14 Unattended User Equipment

- **Question:** Are users required to ensure unattended equipment is protected appropriately, such as logging off or using a screen lock?

Technological Controls (34 controls)

A.8.1 User Endpoint Devices

- **Question:** Are security measures implemented to protect user endpoint devices, such as desktops, laptops, and mobile devices, from security threats?

A.8.2 Privileged Access Rights

- **Question:** Is the allocation and use of privileged access rights restricted and controlled?

A.8.3 Information Access Restriction

- **Question:** Are access restrictions in place to ensure that users only have access to information and information processing facilities that they have been specifically authorized to use?

A.8.4 Access to Source Code

- **Question:** Is access to program source code restricted and controlled?

A.8.5 Secure Authentication

- **Question:** Are users required to follow secure authentication practices, such as using strong passwords and, where appropriate, multi-factor authentication?

A.8.6 Capacity Management

- **Question:** Are capacity demands monitored and projections made of future capacity requirements to ensure adequate system performance?

A.8.7 Protection Against Malware

- **Question:** Are detection, prevention, and recovery controls implemented to protect against malware, combined with appropriate user awareness?

A.8.8 Management of Technical Vulnerabilities

- **Question:** Is information about technical vulnerabilities obtained in a timely fashion, and are exposure to such vulnerabilities evaluated and appropriate measures taken to address the associated risk?

A.8.9 Configuration Management

- **Question:** Are configurations of hardware, software, services, and networks established, documented

A.8.10 Information Deletion

- **Question:** Are there policies and procedures in place to ensure secure deletion of information when no longer required?

A.8.11 Data Masking

- **Question:** Is data masking implemented to protect sensitive information in non-production environments?

A.8.12 Data Leakage Prevention

- **Question:** Are data leakage prevention measures deployed to detect and prevent unauthorized transmission of sensitive information?

A.8.13 Information Backup

- **Question:** Are backup copies of information, software, and system images taken and tested regularly in accordance with an agreed backup policy?

A.8.14 Redundancy of Information Processing Facilities

- **Question:** Are redundant information processing facilities implemented to ensure availability in the event of a system failure?

A.8.15 Logging

- **Question:** Are event logs recorded, protected, and reviewed to support information security?

A.8.16 Monitoring Activities

- **Question:** Are networks and systems monitored to detect anomalies and potential security incidents?

A.8.17 Clock Synchronization

- **Question:** Are clocks of all relevant information processing systems synchronized to a single reference time source?

A.8.18 Use of Privileged Utility Programs

- **Question:** Is the use of utility programs that can override system and application controls restricted and tightly controlled?

A.8.19 Installation of Software on Operational Systems

- **Question:** Are there procedures to control the installation of software on operational systems to prevent unauthorized software installation?

A.8.20 Networks Security

- **Question:** Are networks managed and controlled to protect information in systems and applications?

A.8.21 Security of Network Services

- **Question:** Are security features, service levels, and management requirements of network services identified and included in network services agreements?

A.8.22 Segregation of Networks

- **Question:** Are groups of information services, users, and information systems segregated on networks?

A.8.23 Web Filtering

- **Question:** Are controls implemented to restrict access to inappropriate or malicious websites?

A.8.24 Use of Cryptography

- **Question:** Are policies on the use of cryptographic controls developed and implemented?

A.8.25 Secure Development Life Cycle

- **Question:** Is a secure development life cycle (SDLC) implemented to ensure information security is integrated into the development process?

A.8.26 Application Security Requirements

- **Question:** Are security requirements of applications identified, specified, and documented as part of the development process?

A.8.27 Secure System Architecture and Engineering Principles

- **Question:** Are principles for engineering secure systems established, documented, maintained, and applied to information system engineering activities?

A.8.28 Secure Coding

- **Question:** Are secure coding principles adopted and applied to software development?

A.8.29 Security Testing in Development and Acceptance

- **Question:** Are security functionality and controls tested during development and prior to acceptance?

A.8.30 Outsourced Development

- **Question:** Is outsourced system development supervised and monitored to ensure that information security requirements are met?

A.8.31 Separation of Development, Test, and Production Environments

- **Question:** Are development, testing, and operational environments separated to reduce the risks of unauthorized access or changes?

A.8.32 Change Management

- **Question:** Are changes to information processing facilities and systems controlled through a formal change management process?

A.8.33 Test Information

- **Question:** Is test data selected carefully, protected, and controlled?

A.8.34 Protection of Information Systems During Audit and Testing

- **Question:** Are audit and testing activities planned and agreed to minimize risks to operational systems?